

SOC 2 vs ISO 27001

Cuál elegir según mercado y momento

Fernando Hurtado

Fractional CISO · AI Governance

Elegir mal cuenta 6-9 meses y decenas de miles de dólares.

No es 'cuál es mejor'. Es cuál pide tu cliente, en qué mercado vendes y en qué momento estás. La pregunta correcta no es técnica, es comercial.

Lado a lado

	SOC 2	ISO 27001
Origen	AICPA (US)	ISO (global)
Formato	Reporte de auditor	Certificado
Vigencia	Type II anual	3 años + vigilancia
Scope	Trust Services Criteria	SGSI + Anexo A
Reconocen	US enterprise	Global / Europa

Si vendes a US enterprise

SOC 2 primero

- 1 Es lo que pide procurement en EE.UU. por default.
- 2 El Type II demuestra operación, no solo diseño.
- 3 **Ejemplo:** SaaS B2B vendiendo a clientes tech de US.

LA RAZÓN

Tu comprador ya sabe leer un SOC 2; el ISO le suena lejano.

Si vendes a EU o regulado

ISO 27001 primero

- 1 Reconocimiento internacional y en sectores regulados.
- 2 Certificado: más fácil de presentar fuera de US.
- 3 **Ejemplo:** fintech o healthtech con clientes europeos o gobierno.

LA RAZÓN

En esos mercados el certificado ISO abre puertas que el SOC 2 no.

¿Cuándo los dos?

- 1 Serie B+ vendiendo a US y a Europa a la vez.
- 2 Empieza por el que pida tu cliente más grande hoy.
- 3 El segundo reusa 70-80% de los controles del primero.

LA CLAVE

El orden lo manda tu pipeline comercial, no el framework.

¿Llevas semanas con la pregunta SOC 2 o ISO 27001?

Esta matriz cierra la discusión. Compártela con tu CTO.

cal.com/fernando-hurtado

Fernando Hurtado

Fractional CISO · AI Governance